

Information Gathering and Vulnerability Scanning

CHAPTER 2

2.01

Episode **Scanning and Enumeration**
title:

Objective: **2.2 Given a scenario, perform active reconnaissance**

PENTEST+ EXAM OBJECTIVES

DOMAIN	PERCENTAGE OF EXAM
1.0 Engagement Management	13%
2.0 Reconnaissance and Enumeration	21%
3.0 Vulnerability Discovery and Analysis	17%
4.0 Attacks and Exploits	35%
5.0 Post-exploitation and Lateral Movement	14%
TOTAL	100%

RECONNAISSANCE

- **Scanning**

- Process of looking at some number of “things” to determine characteristics
- Commonly used in pen testing to uncover target vulnerabilities

- **Many types of scan targets**

- Networks
- Network devices
- Computers
- Applications/services

ENUMERATION

- **Counting the detected instances of some target class**
- **Pen testing target classes**
 - Hosts
 - Networks
 - Domains
 - Users
 - Groups
 - Network shares
 - Web pages
 - Applications
 - Services
 - Tokens
 - Social networking sites

2.02

Episode **Scanning Demo**
title:

Objective: **2.3 Given a scenario, analyze the results of a reconnaissance exercise**

SCANNING AND ENUMERATION

- Nmap demo
- Whois demo

2.03

Episode **Packet Investigation**
title:

Objective: **2.2 Given a scenario, perform active reconnaissance**
2.3 Given a scenario, analyze the results of a reconnaissance exercise

PACKET INVESTIGATION

- **Packet crafting**

- Creating specific network packets to gather information or carry out attacks
- Tools – netcat, nc, ncat, hping

- **Packet inspection**

- Capturing and analyzing network packets
- Wireshark

INSPECTING TARGETS

- **Fingerprinting**

- Determining OS type and version a target is running

- **Cryptography**

- Inspecting certificates

EAVESDROPPING

- **RF communication monitoring**
- **Sniffing**
 - Intercepting packets and inspecting their contents
 - Wired
 - Wireshark and tcpdump
 - Wireless
 - Aircrack-ng

2.04

Episode **Packet Inspection Demo**
title:

Objective: **2.2 Given a scenario, perform active reconnaissance**

PACKET INSPECTION DEMO

- Wireshark Demo

2.05

Episode **Labtainers Setup**
title:

Objective: **(none)**

Lab: Introducing Labtainers

- **Labtainers overview**
 - <https://nps.edu/web/c3o/labtainers>
- **Installing Virtualbox**
 - <https://www.virtualbox.org/>
- **Downloading Labtainers appliance**
- **Installing Labtainers**
- **Configuring/updating Labtainers**
 - <https://nps.edu/web/c3o/support1>
- **Launching Labtainers**

2.06

Episode **Labtainers Lab (Wireshark)**
title:

Objective: **2.2 Given a scenario, perform active reconnaissance**

2.07

Episode title: **Application and
Open-Source Resources**

Objective:

DECOMPILATION

- **Compiler** – translates source code into executable instructions
- **Decompiler** – attempts to convert executable instructions back into source code
 - Output is generally awkward to read at best
- **Sometimes target is not a direct executable (i.e. Java)**

DEBUGGING

- **Running an executable in a controlled manner**
- **Debuggers make it easy to stop and examine memory at will**
- **Can reveal a program's secrets and weaknesses**
- **Tools - windbg**

OPEN SOURCE INTELLIGENCE GATHERING

- **Open Source Intelligence Gathering (OSINT)**
- **Sources of research**
 - Computer Emergency Response Team (CERT) -
<https://www.us-cert.gov/>
 - National Institute of Standards and Technology (NIST) -
<https://csrc.nist.gov/>
 - Japan's CERT (JPCERT) -
<https://www.jpcert.or.jp/english/vh/project.html>

OPEN SOURCE INTELLIGENCE GATHERING, cont'd

- **More sources of research**
 - Common Attack Pattern Enumeration & Classification (CAPEC) - <https://capec.mitre.org/>
 - Full disclosure – Popular mailing list from the folks who brought us nmap - <http://seclists.org/fulldisclosure/>

OPEN SOURCE INTELLIGENCE GATHERING, cont'd

- **More sources of research**
 - Common Vulnerabilities and Exposures (CVE) - <https://www.cve.org/>
 - Common Weakness Enumeration (CWE) - <https://cwe.mitre.org/>

2.08

Episode **Prioritize and Prepare Attacks**
title:

Objective: **4.1.1.2.1, 4.1.1.2.4, 4.1.1.3, 4.1.1.4, 4.1.1.5, 4.1.1.6, 4.1.1.7**

SCORING MODELS

- **Common Vulnerability Scoring System (CVSS)**
- **Exploit Prediction Scoring System (EPSS)**

COMMON VULNERABILITY SCORING SYSTEM (CVSS)

- **Quantifies severity of a vulnerability**
- **Factors:**
 - Attack complexity
 - Required privileges
 - Impact on confidentiality
 - Integrity
 - Availability
- **Scores range from 0 to 10**

EXPLOIT PREDICTION SCORING SYSTEM (EPSS)

- Predictive layer to vulnerability management
- Probability score from 0 to 1
- Combines with CVS for prioritization

END OF LIFE SOFTWARE

- No security patches, updates, or documentation
- Prime targets for attackers
- Importance of identifying and prioritizing

DEFAULT CONFIGURATIONS

- Hard coded passwords, open ports, insecure settings
- Easily exploited
- Importance of prioritizing during tests

VULNERABLE SERVICES

- **Outdated, unnecessary, or misconfigured services**
- **High value targets in penetration tests**
- **Examples:**
 - FTP
 - Telnet
 - Unauthenticated databases

WEAK ENCRYPTION

- **Commonly found in production environments**
- **Examples:**
 - SSL
 - TLS 1.0
 - MD5
 - SHA-1
- **Importance of testing for these issues**

DEFENSIVE CAPABILITIES

- Influence on target prioritization
- Systems protected by EDR, firewalls, or intrusion detection systems
- Evaluating effectiveness of detection and response

2.09

Episode **Passive Reconnaissance**
title:

Objective: **2.1 Given a scenario, perform passive reconnaissance**

PERFORM PASSIVE RECONNAISSANCE

- **Cloud vs. self-hosted**
- **Social media scraping**
- **Cryptographic flaws**
 - Secure Sockets Layer (SSL) certificates
 - <https://gbhackers.com/testssl-sh-tls-ssl-vulnerabilities/>
 - Revocation
 - Learn how and why tokens are revoked
 - Avoid allowing revocation of tokens used in tests

PERFORM PASSIVE RECONNAISSANCE

- **Data**

- Password dumps
 - <https://haveibeenpwned.com/>
- File metadata
 - Location/date/time/additional info
- Strategic search engine analysis and enumeration
 - Shodan
 - <https://www.shodan.io/>
 - Censys
 - <https://censys.io/>

PERFORM PASSIVE RECONNAISSANCE

- **Data**

- Web site archiving and caching
 - <https://www.exploit-db.com/google-hacking-database>
 - Waybackmachine
 - <https://archive.org/>

PERFORM PASSIVE RECONNAISSANCE

- **Data**

- Public source code repositories
 - GitHub
 - <https://github.com/>
 - Sourceforge
 - <https://sourceforge.net/>
 - Bitbucket
 - <https://bitbucket.org/>

OPEN-SOURCE INTELLIGENCE (OSINT)

- **Tools**

- Recon-ng
 - <https://www.kali.org/tools/recon-ng/>
- ThreatPinchLookup
 - <https://github.com/cloudtracer/ThreatPinchLookup>

OPEN-SOURCE INTELLIGENCE (OSINT)

- **Tools**

- vFeed
 - <https://github.com/toolswatch/vFeed>
- Vulnix
 - <https://github.com/flyingcircusio/vulnix>
- Great list of OSINT tools
 - <https://securitytrails.com/blog/osint-tools>

OPEN-SOURCE INTELLIGENCE (OSINT)

- **Sources**

- National Vulnerability Database (NVD)
 - <https://nvd.nist.gov/>
- CVE versus NVD?
 - https://cve.mitre.org/about/cve_and_nvd_relationship.html

2.10

Episode title: **Active Reconnaissance**

Objective: **2.2 - Given a scenario, perform active reconnaissance**

PERFORM ACTIVE RECONNAISSANCE

- **Defense detection**

- Load balancer detection
- Web application firewall (WAF) detection
 - WafW00f (Python tool)
 - <https://github.com/sandrogauci/wafw00f>
 - http-waf-detect nmap script
 - <https://nmap.org/nsedoc/scripts/http-waf-detect.html>

PERFORM ACTIVE RECONNAISSANCE

- **Defense detection**

- Antivirus
 - Examine e-mail headers and footers
 - BeEF / mitmf (Kali)
 - <https://securityonline.info/detect-antivirus-software-victim-machine-without-user-interaction/>
- Firewall
 - Firewalk (Kali)
 - <https://www.kali.org/tools/firewalk/>

PERFORM ACTIVE RECONNAISSANCE

- **Wardriving**

- Great overview/resource
 - <https://www.geeksforgeeks.org/wardriving-introduction/>

- **Cloud asset discovery**

- CloudBrute (Kali)
 - <https://www.kali.org/tools/cloudbrute/>
- OWASP Amass
 - <https://github.com/OWASP/Amass>

PERFORM ACTIVE RECONNAISSANCE

- **Third-party hosted services**
 - Similar approach to cloud asset discovery
 - Often more restrictions (external)
- **Detection avoidance**
 - Passive reconnaissance presents the lowest risk of detection
 - Active reconnaissance options may be noisy and more likely to trigger alarms
 - Determine the level of stealth desired

2.11

Episode title: **Additional Enumeration Techniques**

Objective: **2.2.16 (a,b,c), 4.2.2.4, 4.2.2.7**

WEB CRAWLING AND RECONNAISSANCE

- **robots.txt**

- Instructs web crawlers as to which pages or directories to avoid
- Attackers check this file for hidden directories, admin panels, staging environments

- **sitemap.xml**

- Lists all discoverable URLs on a site
 - Non-linked pages
 - Password reset flows
 - Staging and testing environments

PEN TESTING TOOLS

- **In Packet**

- Python toolkit for low-level interaction with network protocols:
 - SMB
 - RDP
 - Kerberos
 - NTLM
- Uses:
 - NTLM relaying
 - Credential dumping
 - Remote code execution

PEN TESTING TOOLS

- **In Packet**
- **MSF Venom**
 - Metasploit payload generation tool
 - Allows creation of custom payloads
 - Standalone
 - Executable scripts
 - Shell code

2.12

Episode **Vulnerability Scanning**
title:

Objective: **2.4 Given a scenario, perform vulnerability scanning**

VULNERABILITY SCAN

- **Structured approach to examining targets to identify known weaknesses**
- **Many different types**
- **Determine if any known weaknesses exist**

CREDENTIALLED VS. NON-CREDENTIALLED

- **Credentialed (authenticated)**
 - Accessing resources using valid credentials
 - More detailed, accurate information
- **Non-credentialed (non-authenticated)**
 - Anonymous access to exposed resources
 - Fewer details, often used in early phases of attacks/tests

TYPES OF SCANS

- **Discovery scan – used to find potential targets**
 - Identity/info gathering early on
 - nmap ping sweep

```
nmap -sP target
```

TYPES OF SCANS

- **Full scan**

- Scans ports, services, and vulnerabilities

```
nmap -A <target>
```

```
perl nikto.pl -h <target>
```

- OpenVAS

- **Port scan**

```
nmap -p <ports> <target>v
```

TYPES OF SCANS

- **Stealth scan**

- Attempt to avoid tripping defensive control thresholds

```
nmap -sS <target>
```

- **Compliance**

- Scan for specific known vulnerabilities that would make a system non-compliant

2.13

Episode **Vulnerability Scanning Demo**
title:

Objective: **2.4 Given a scenario, perform vulnerability scanning**

Scanning Demo

- Nmap
- Nikto
- OpenVAS

2.14

Episode title: **Labtainers Lab (Network Basics)**

Objective: **2.2 Given a scenario, perform active reconnaissance**

2.15

Episode **Labtainers Lab (Nmap Discovery)**
title:

Objective: **2.4 Given a scenario, perform vulnerability scanning**

2.16

Episode **Target Considerations**
title:

Objective: **2.4 Given a scenario, perform vulnerability scanning**

CONTAINER

- **Lightweight instance of a VM**
 - Runs on top of host OS
- **Docker, Puppet, Vagrant**

APPLICATION SCAN

- **Dynamic analysis**

- Target environment is running and responds to queries

- **Static analysis**

- Collect artifacts for post-execution analysis

SCANNING CONSIDERATIONS

- **Time to run scans**
 - Approved schedule (planning)
- **Protocols used**
 - Largely dependent on target selection
- **Network topology**
 - Network layout (diagram) of test targets
- **Bandwidth limitations**
 - Tolerance to impact (affects availability)

SCANNING CONSIDERATIONS

- **Query throttling**

- Slow down test iterations to avoid exceeding bandwidth
 - nmap -T

- **Fragile systems/non-traditional assets**

- How to avoid impacting fragile mission critical systems?

ANALYZE SCAN RESULTS

- **Asset categorization**

- Identify and rank assets by relative value
- Vulnerable assets with little value could be a waste of time

- **Adjudication**

- Determine which results are valid
 - False positives
 - Filter out false positives

ANALYZE SCAN RESULTS

- **Prioritization of vulnerabilities**

- Highest impact vulnerabilities
 - Ease of exploit vs. payoff

- **Common themes**

- Vulnerabilities
- Observations
- Lack of best practices

2.17

Episode **Analyzing Scan Output**
title:

Objective: **2.3 Given a scenario, analyze the results of a reconnaissance exercise. 2.1.5, 2.1.6, 2.1.9**

ANALYZE OUTPUT

- **DNS lookups**

- Nslookup
- Whois
 - <https://www.whois.com/whois/>

ANALYZE OUTPUT

- **Crawling websites**

- Netcat
- W3af
 - <http://w3af.org/>
- Burp Suite (Kali)
 - <https://www.kali.org/tools/burpsuite/>

ANALYZE OUTPUT

- **Crawling websites**

- Crawlorgo
 - <https://hacker-gadgets.com/blog/2021/10/15/crawlorgo-a-powerful-browser-crawler-for-web-vulnerability-scanners/>
- OWASP zaproxy (Kali)
 - <https://www.kali.org/tools/zaproxy/>

ANALYZE OUTPUT

- **Network traffic**

- Wireshark
 - <https://www.wireshark.org/>

- **Address Resolution Protocol (ARP) traffic**

- Wireshark
 - <https://www.wireshark.org/>

ANALYZE OUTPUT

- **Nmap scans**
- **Web logs**
 - IIS
 - <https://www.sumologic.com/blog/iis-logs/>
 - Apache
 - <https://linuxconfig.org/how-to-analyze-and-interpret-apache-webserver-log>

CERTIFICATE TRANSPARENCY (CT) LOGS

- **Public records of SSL or TLS certificates issued by certificate authorities**
- **Detect fraud or mis-issuance**
- **Provide valuable reconnaissance tools for security professionals**

QUERYING CT LOGS

- **Uncover previously unseen subdomains**

- dev.domain.com
- vpn.domain.com

- **Tools**

- CRT dot SH
- Google's CT Log Viewer

MAPPING WEB PRESENCE WITH CT LOGS

- **Benefits**
 - Map organization's web presence
 - Useful for testing large or complex infrastructures

INFORMATION DISCLOSURE

- **Accidental data exposure**
- **Common sources**
 - Verbose error messages
 - Code comments
 - Misplaced backup files
 - Headers that expose system details

RISKS OF INFORMATION DISCLOSURE

- **Potential leaks**
 - Usernames
 - Internal email addresses
 - Internal IP addresses
 - Software versions
- **Tools for Discovery**
 - Google Dorking
 - Burp Suite
 - Derbuster

BANNER GRABBING

- **Identifying software and version via welcome message or header data**
- **Common Services**
 - FTP
 - SSH
 - HTTP
 - SMTP

BANNER GRABBING

- **Tools**

- Netcat
- Nmap
- Telnet

- **Match exposed services to known vulnerabilities during enumeration**

2.18

Episode title: **Nmap Scoping and Output Options**

Objective: **2.4 Given a scenario, perform vulnerability scanning**

NMAP

- **Network Mapper (nmap)**

- One of the most common and most useful tools for reconnaissance
- `nmap -A`
 - does much of what we're about to see

SYN SCAN vs. FULL CONNECT SCAN

- **Synchronized (SYN) stealth scan**
 - nmap -sS target
 - Sends SYN packet and examines response (SYN/ACK means the port is open)
 - If SYN/ACK received, nmap sends RST to terminate the connection request
- **Full connect scan**
 - nmap -sT target
 - Completes the handshake steps to establish a connection (more reliable)

PORT SELECTION (-p)

- **Scans a range of ports**

- `nmap-p <range of ports> target`
 - p 21
 - p 1-10000
 - p U:53,137,161T:21-37,80,8080

OR

- exclude-port <range of ports>

SERVICE IDENTIFICATION (-sV)

- **Attempts to determine service and version info**

- `nmap -sV <target>`
 - `version-intensity <level>`,
where level can be 0 (light)
to 9 (execute all probes)

GATHERING INFORMATION WITH NMAP

- **OS fingerprinting (-O)**
 - Detects target OS
 - `nmap -O <target>`
- **Disabling ping (-Pn)**
 - Skips host discovery (assumes all are online)
 - `nmap -Pn <target>`

GATHERING INFORMATION WITH NMAP

- **Target input file (-iL)**
 - Uses a text file that contains a list of targets
 - nmap -iL <inputFileName>
 - Can also exclude targets from a range
 - nmap -excludefile <excludeFileName>

TIMING (-T)

- **Changes how long nmap waits for a response (default is -T 3)**

- Values range from 0 (Paranoid, slow) to 5 (Insane, fast)

OUTPUT PARAMETERS

- **-oA – Combined format**

- Normal .txt, XML .xml, and greppable .txt

- **-oN**

- Normal output file (.nmap)

- **-oG**

- Greppable output file (.gnmap)

- **-oX**

- XML output format (.xml)

2.19

Episode title: **Nmap Timing and Performance Options**

Objective: **2.4 Given a scenario, perform vulnerability scanning**

Scanning demo

- Nmap demo

2.20

Episode **Prioritization of Vulnerabilities**
title:

Objective: **2.4 Given a scenario, perform vulnerability scanning**

LEVERAGE INFORMATION

- **Leveraging information to prepare for exploitation**
- **Map vulnerabilities to potential exploits**
 - Look up vulnerabilities found for possible exploits
 - Nmap – vulners and vulscan scripts
 - Metasploit (search vulnerability)

LEVERAGE
INFORMATION

RANK ASSETS

RANK VULNERABILITIES

RANK EXPLOITS

LEVERAGE INFORMATION

- **Prioritize activities**
 - Will standard exploits work?
 - Will exploits need to be 'tweaked'?
 - Additional steps to prepare test?

Demo

- Demo

2.21

Episode **Common Attack Techniques**
title:

Objective: **2.4 Given a scenario, perform vulnerability scanning**

COMMON ATTACK TECHNIQUES

- **Some Windows exploits can be run in Linux**
- **Cross-compiling code**
 - Compile exploit for another OS
 - <https://www.hackingtutorials.org/exploit-tutorials/mingw-w64-how-to-compile-windows-exploits-on-kali-linux/>

COMMON ATTACK TECHNIQUES

- **Exploit modification**

- May need to modify for success of evasion

- **Exploit chaining**

- Compromise one device/system to gain access to another

- **Proof-of-concept development**

- Exploit development

COMMON ATTACK TECHNIQUES

- **Social engineering**
 - Help me
 - Urgent
 - Deceptive
- **Credential brute forcing**
- **Enlightened attacks**
 - Dictionary
 - Rainbow table

2.22

Episode **Automating Vulnerability Scans**
title:

Objective: **2.4 Given a scenario, perform vulnerability scanning**

AUTOMATION

- **Repeatability**
- **Minimal interaction**
- **Exception-only notification**
- **Must handle multiple environments**
 - Multi-OS
 - Cloud, on-premises, and third-party

VULNERABILITY TOOLS AND AUTOMATION

- **Command-line tools are easy to automate**
 - Scripts
 - Schedulers
 - Analysis to minimize false positives

2.23

Episode **Credential Attacks**
title:

Objective: **(none)**

Demo – Password cracking

- **Demo – Hydra**
- **Bad usernames and passwords**
 - Daniel Miessler's SecLists -
<https://github.com/danielmiessler/SecLists/tree/master/Passwords>

2.24

Episode title: **Labtainers Lab (Password Cracking)**

Objective: **2.1 Given a scenario, perform passive reconnaissance**

2.25

Episode title: **Labyrinth Lab (Secure Socket Layers)**

Objective: **2.1 Given a scenario, perform passive reconnaissance**

2.26

Episode **Labtainers Lab (Routing Basics)**
title:

Objective: **2.1 Given a scenario, perform passive reconnaissance**